

Product Requirements Document — DrishtiMail Forensics

Client: Smart India Hackathon (problem statement SIH26106, AICTE — Cyber Security Cell)

Prepared by: fiftyfive technologies

Date: 2026-08-31

Status: Draft — pending review

1. Problem

Institutions can block malicious email but cannot explain, trace, or evidence it. When a spoofed invoice or a credential-harvesting mail impersonating a Registrar arrives, the security team can quarantine it and still not answer where it came from, which infrastructure sent it, whether it matches a prior incident, or how to hand it to law enforcement in a usable form. Four gaps drive this: semantic, forensic, attribution, and evidentiary — no chain of custody means findings do not survive legal or disciplinary scrutiny.

2. Goals

⚠ Goals not yet measurable — success metrics deferred; see section 8. The system reports its own measured performance on a stated held-out set (M12) but commits to no target.

3. Users

Primary: SOC / security analysts — the daily driver, ~60–100 flagged mails per day, needs a verdict and its reasons in under 30 seconds. Cyber forensic investigators — the escalation path, needs relay reconstruction, infrastructure attribution and defensible evidence. Mail administrators — deploy and configure it, and require that mail flow is never at risk.

Secondary: Institutional head / registrar (sponsor and risk owner), end users (staff, faculty, students) as the protected party, law enforcement / cybercrime cell as report consumers, legal / DPO / compliance, CERT-In as nodal agency.

4. User Stories

M1 — Ingestion & Normalisation

- As a SOC analyst, I want flagged email to arrive in my queue already parsed and scored, so that I can open it and triage without preparing it first.
- As a SOC analyst, I want to upload a single message or a bulk archive, so that I can analyse mail that reached me outside the automatic feed.
- As a SOC analyst, I want to paste raw headers directly, so that I can get a reading on a message I only have a fragment of.
- As a mail administrator, I want messages pulled from the institution's mail platform automatically, so that coverage does not depend on anyone remembering to submit one.

- As a mail administrator, I want every message hashed the moment it arrives and the original preserved unaltered and byte-addressable, so that every later finding can point at an exact location in what was actually received.
- As a mail administrator, I want malformed messages handled and flagged rather than dropped, so that a broken message becomes an anomaly signal instead of a silent gap.
- As a SOC analyst, I want repeat copies of the same message recognised as one, so that a mass-send does not flood the queue.
- As a mail administrator, I want a programmatic submission endpoint, so that another system can send messages for analysis.

M2 — Detection Engine (NLP/ML)

- As a SOC analyst, I want messages classified into distinct threat categories with a calibrated probability, so that I can tell a payment-diversion attempt from a malware carrier.
- As a SOC analyst, I want social-engineering pressure detected explicitly — urgency, authority, secrecy, financial instruction, threat of consequence — so that intent is assessed independently of specific wording.
- As a SOC analyst, I want the specific fraud patterns identified — bank-detail change, fake invoice, gift-card request, payroll diversion, credential harvest, executive impersonation — so that I know which playbook applies.
- As a SOC analyst, I want a message flagged when its display name matches a protected individual but its sending domain does not, so that impersonation of leadership is caught even when the text reads normally.
- As a SOC analyst, I want lookalike sending domains detected, so that a visually near-identical domain is not mistaken for the real one.
- As a SOC analyst, I want concealment techniques in message bodies detected, so that content hidden from a reader but present in the message is surfaced.
- As a SOC analyst, I want replies injected into threads with no legitimate prior history flagged, so that a hijacked conversation is not trusted on the strength of its subject line.
- As a SOC analyst, I want message bodies analysed in languages other than English, so that coverage does not depend on the attacker writing in one language.
- As a SOC analyst, I want to mark a verdict as wrong and have that correction retained for retraining, so that repeated false positives improve the system rather than just annoying me.

M3 — Header & Protocol Analysis

- As a forensic investigator, I want the relay chain reconstructed with every hop below the trust boundary marked unverified, so that I do not build a case on a hop the attacker could have forged.
- As a forensic investigator, I want to read what an authentication result establishes, what it does not establish, and its effect on this investigation, so that I do not mistake "authenticated" for "trustworthy".
- As a forensic investigator, I want a message that passes all authentication checks on a lookalike domain to say so plainly, so that I understand it is authenticated by the attacker rather than by the organisation it claims to be.
- As a forensic investigator, I want authentication results computed independently and compared against those already in the message, so that a disagreement is surfaced rather than inherited.
- As a forensic investigator, I want forwarded and mailing-list mail evaluated on its forwarding chain, so that legitimate forwarding is not scored as a failure.
- As a forensic investigator, I want header inconsistencies detected — mismatched return paths, unrelated reply addresses, malformed identifiers, impossible inter-hop timing — so that tampering is visible without reading the raw source.
- As a forensic investigator, I want suspicious relay characteristics identified, so that a residential or open-relay origin is recognised as unusual for business mail.
- As a forensic investigator, I want a per-hop table showing timestamp, claimed host, actual address, reverse lookup, transport security, delay and trust status, so that the whole path is legible at once.

M4 — Origin Traceability & Location

- As a forensic investigator, I want the earliest reliable originating address selected for me with written justification, so that I trace the real origin rather than a forged hop.
- As a forensic investigator, I want every candidate originating address extracted, so that the selection is made from the full set rather than the first one found.
- As a forensic investigator, I want the origin resolved to country, region, city and accuracy radius, so that I have a geographic starting point.
- As a forensic investigator, I want the network operator and organisation identified, so that I know which infrastructure provider was used.
- As a forensic investigator, I want the infrastructure classified as residential, business, datacenter, anonymising or relay, so that I can tell an actor's own connection from rented or anonymising infrastructure.
- As a forensic investigator, I want every location result carried with an explicit confidence level and caveat, so that I do not overstate a probabilistic finding in a report.
- As a forensic investigator, I want the hop path drawn on an interactive map, so that the route is comprehensible to a reader who will not read a hop table.
- As a forensic investigator, I want registration intelligence on the sending domain, so that I can judge how established the sender actually is.
- As a forensic investigator, I want high-risk registration traits flagged, so that a domain registered days ago is treated differently from one registered years ago.
- As a forensic investigator, I want historical resolution data for the domain, so that I can see what the infrastructure looked like before this message was sent.
- As a mail administrator, I want enrichment results cached with a defined lifetime, so that repeat analysis does not exhaust an external quota.

M5 — Investigation & Correlation Graph

- As a SOC analyst or forensic investigator, I want related emails grouped under one campaign with their shared indicators listed, so that I recognise a repeat campaign instead of treating each message as isolated.
- As a forensic investigator, I want campaign membership decided by stated shared indicators rather than an opaque grouping, so that I can defend the assertion that two messages belong together.
- As a forensic investigator, I want the same phishing template recognised across different wording and different domains, so that a reused kit is caught even when the text changes.
- As a forensic investigator, I want to know whether an indicator has been seen at this institution before, and how often, so that novelty is distinguished from familiarity.
- As a SOC analyst, I want first contact presented as novelty rather than as evidence of maliciousness, so that a new supplier is not treated as an attacker.
- As a forensic investigator, I want to pivot from any node in the correlation view to what it connects to, so that I can follow a thread of shared infrastructure without starting a new search.
- As a forensic investigator, I want every campaign edge to link through to the evidence that justifies it, so that no relationship is asserted without support.
- As a forensic investigator, I want indicators extracted from every message, so that each incident contributes to a searchable body of evidence.
- As a forensic investigator, I want the origin scenario classified with confidence, so that the investigation starts from a stated hypothesis.
- As a forensic investigator, I want the attribution written as a confidence-scored lead about infrastructure and never as an identity assertion, so that the finding stays within what the evidence supports.

- As a forensic investigator, I want indicators exported in standard interchange formats, so that another team can consume them without re-keying.

M6 — Alerting, Dashboard & Reporting

- As a SOC analyst, I want a queue of flagged mail with filters and a detail view carrying verdict, contributing signals, authentication semantics, hop table, map and domain intelligence, so that I can triage without leaving the screen.
- As a forensic investigator, I want the case view to present hop table, origin selection, geolocation and domain intelligence together, so that a deep-dive does not require assembling the picture by hand.
- As a SOC analyst or forensic investigator, I want the correlation view reachable from any email or case, so that campaign context is one step away from the message that raised it.
- As a forensic investigator, I want to export a forensic report carrying evidence references, hashes, custody entries, tool version and an integrity root, so that the finding can be handed to a reviewer as a self-contained artifact.
- As a SOC analyst, I want high-risk verdicts to raise an alert before anyone interacts with the message, so that response can begin ahead of the recipient acting on it.
- As a mail administrator, I want alert destinations and score thresholds to be configurable, so that alerting matches how the team actually works.
- As an institutional head, I want a dashboard of volume trends, verdict distribution, most-targeted departments and campaign activity, so that I can see the institution's exposure without reading individual messages.
- As a forensic investigator, I want an admissibility certificate template generated with the report, so that the electronic record is packaged in the form a legal reviewer expects.
- As a SOC analyst, I want to create a case, attach related emails, assign an owner and move it through a status workflow, so that an investigation has a place to live beyond a single message.
- As a SOC analyst, I want to search all historical mail and cases by text and by indicator, so that I can find a prior occurrence without knowing which case it was filed under.
- As an end user, I want to report a suspicious message and have it enter the analyst queue directly, so that my report becomes an analysed item rather than an email to someone's inbox.

M7 — Evidence Integrity Layer

- As a forensic investigator, I want every finding bound to an exact location in the preserved original, so that every sentence in a report traces to a byte in the message.
- As a forensic investigator, I want an exported report's integrity independently verifiable, so that an altered file fails verification and an unaltered one passes.
- As a forensic investigator, I want the verification tool to run without access to the live system, so that a third party can check our evidence without trusting our infrastructure.
- As a compliance officer, I want the evidence record to be append-only at the storage layer, so that integrity does not depend on application code behaving correctly.
- As a compliance officer, I want any retroactive edit to break the record detectably from that point onward, so that tampering cannot be concealed by editing one row.
- As a compliance officer, I want content masked by default with any reveal recorded as an audited action, so that access to personal data is deliberate and traceable.
- As a compliance officer, I want access restricted by role across viewing, investigating, administering and auditing, so that permission matches responsibility.
- As a compliance officer, I want retention configurable per data class with automatic removal and a record of what was removed, so that data is not held longer than policy allows.
- As a compliance officer, I want evidence under an active case protected from automatic removal, so that a retention rule cannot destroy material an open investigation depends on.

- As a compliance officer, I want storage location constrained to the required jurisdiction, so that residency obligations are met by the system rather than by procedure.

M8 — Administration

- As a mail administrator, I want to maintain the list of trusted internal mail servers, so that the trust boundary the relay analysis depends on reflects our actual infrastructure.
- As a mail administrator, I want to maintain the list of protected individuals and brands, so that impersonation detection knows who is worth impersonating here.
- As a mail administrator, I want to maintain allow and block lists with expiry, so that a temporary exception does not become permanent by neglect.
- As a mail administrator, I want scoring weight ceilings and verdict thresholds to be configurable, so that scoring can be tuned without a code change.
- As a mail administrator, I want the volume threshold below which the first-contact signal is suppressed to be configurable, so that the signal stays silent until it is meaningful.
- As a mail administrator, I want model versions tracked with training date, calibration date and measured performance, and the ability to revert, so that a bad model can be withdrawn.

M9 — URL & Embedded Content Threat Engine

- As a SOC analyst, I want a QR code in an attached invoice decoded and its destination expanded, so that a payload deliberately kept out of the message text is still examined.
- As a SOC analyst, I want QR codes found in inline images, image attachments and document pages alike, so that the extraction surface does not decide whether a threat is seen.
- As a SOC analyst, I want a QR code that is detected but cannot be decoded reported as present and undecodable, so that an unreadable code in a payment email is itself a flag rather than a silence.
- As a SOC analyst, I want links from the body, from images and from attachments checked by the same pipeline, so that a URL is assessed identically regardless of how it arrived.
- As a SOC analyst, I want links expanded through their redirect chain and checked for mismatch between displayed text and destination, so that a disguised destination is visible before anyone clicks it.
- As a SOC analyst, I want attachments examined without being opened, so that a malicious file is identified without being run.
- As a forensic investigator, I want each URL tagged with how it was obtained, so that a body-versus-QR divergence can be detected downstream.

M10 — Evidence Conflict Detector

- As a SOC analyst, I want contradictions between analysis results named and shown with both sides quoted, so that "authenticated but misaligned" reads as a finding rather than two unrelated facts.
- As a forensic investigator, I want an authentication pass alongside high content risk identified as likely account compromise rather than spoofing, so that I start from the right hypothesis.
- As a forensic investigator, I want an authentication failure on a validly forwarded message identified as probable mailing-list traffic, so that forwarding is not mistaken for an attack.
- As a SOC analyst, I want a divergence between a QR destination and every link in the body called out, so that a payload kept out of the text is recognised as deliberate.
- As a forensic investigator, I want a mismatch between origin geography and the claimed sending organisation surfaced, so that a registrar in one place and an origin in another is visible.
- As a forensic investigator, I want a message reported as known-bad by a feed but never seen here before identified as a known campaign's first local appearance, so that external and internal knowledge are reconciled.

M11 — Explainable Threat Scoring

- As a SOC analyst, I want each contributing signal listed with its actual point value summing visibly to the total, so that I can see how the score was reached rather than trust it.
- As a SOC analyst, I want every score to carry a confidence band and fixed disclaimer language, so that an assessment is never read as a determination of fact.
- As a forensic investigator, I want each contribution linked to the evidence it came from, so that I can move from a number to the byte in the original message behind it.
- As a SOC analyst, I want no single category of signal able to reach the escalation threshold on its own, so that one noisy detector cannot drive a verdict.
- As a SOC analyst, I want a contradiction between signals to adjust the score with the reasoning recorded, so that an authenticated message with hostile content is not scored as if both facts were independent.
- As a SOC analyst, I want verdict labels expressed as assessments rather than conclusions, so that the interface never claims certainty the evidence does not support.

M12 — ML Evaluation & Model Validation

- As a mail administrator, I want per-class precision, recall and F1 on a stated held-out set shown with the test-set size, so that reported accuracy is checkable rather than asserted.
- As a mail administrator, I want what the corpus does not cover stated on the same screen as the results, so that the limitation travels with the number.
- As a mail administrator, I want evaluation to run away from the per-message analysis path, so that measurement never affects live processing.
- As a mail administrator, I want evaluation results written to the model registry, so that a model's measured performance is recorded against its version.

5. Scope

In

Feature	Description	Confidence
M1 — Ingestion & Normalisation	Message-file upload (single + bulk archive), pasted headers, mail platform API ingestion, mailbox polling, journaling stream; structure parse, hash at ingest, write-once original, malformed-message tolerance, deduplication, programmatic analysis endpoint	HIGH
M2 — Detection Engine (NLP/ML)	Six-class classification with calibrated probability, social-engineering cues, payment-fraud sub-patterns, display-name spoofing, lookalike-domain detection, concealment-technique detection, thread-hijack detection, multilingual body analysis, feature attribution, analyst feedback and retraining queue	HIGH
M3 — Header & Protocol Analysis	Relay-chain parsing, trust-boundary logic, sender-authentication validation with alignment, authentication-results cross-check, forwarding-chain evaluation, header-anomaly and relay-characteristic detection, per-hop table, and authentication semantics — what each result establishes, does not establish, and its effect on the investigation	HIGH
M4 — Origin Traceability & Location	Candidate address extraction, earliest-reliable-origin selection with justification, geographic and network-operator resolution, infrastructure-type classification, mandatory confidence bands, interactive trace map, domain registration intelligence, high-risk domain flags, historical resolution data, enrichment caching	HIGH
M5 — Investigation & Correlation Graph	Indicator extraction, threat-feed correlation, property graph with typed nodes and edges, campaign membership by explainable shared-indicator scoring, structural fingerprinting over message skeleton, first-contact familiarity bands over institutional history, origin-scenario classification, confidence-scored leads, indicator export, pivot explorer	HIGH

Feature	Description	Confidence
M6 — Alerting, Dashboard & Reporting	Real-time alerts with configurable destinations and thresholds, analyst queue, email detail view, executive dashboard, forensic report with evidence-integrity page, admissibility certificate template, case management, full-text and indicator search, end-user reporting intake, and the interface surfaces for conflict, semantics, scoring and integrity	HIGH
M7 — Evidence Integrity Layer	Role-based access control (5 roles), content masking with audited reveal, configurable retention with automated removal, residency enforcement, legal-hold flag, evidence references binding every finding to an exact location in the preserved original, storage-enforced append-only hash-chained record, periodic integrity root exported with each report, standalone verification tool	HIGH
M8 — Administration	Protected-brand/individual list, trusted internal mail-server list, allow/block list with expiry, scoring weight and threshold configuration, first-contact suppression floor, model registry	HIGH
M9 — URL & Embedded Content Threat Engine	Hyperlink extraction, attachment static analysis, and QR-code detection across inline images, image attachments and rasterised document pages — all converging on one URL set, then redirect expansion, display-versus-destination comparison, typosquatting check and feed lookup, with provenance tagging	HIGH
M10 — Evidence Conflict Detector	Named contradictions between module outputs, each quoting both sides: authenticated but misaligned, reply-path divergence, authentication pass versus content risk, authentication failure versus benign content, display versus destination, QR versus body divergence, geography versus claim, header versus relay timing, feed versus baseline	HIGH
M11 — Explainable Threat Scoring	Transparent weighted-additive model over normalised signals with per-family weight ceilings, conflict adjustment, clamped range. Mandatory output contract: ranked contributions summing visibly to the total, confidence band, fixed disclaimer language, and a link from each contribution to its evidence reference	HIGH
M12 — ML Evaluation & Model Validation	Held-out evaluation with per-class precision, recall and F1, test-set size, and explicit statement of what the corpus does not cover. Administrative only, off the per-message path	HIGH

Out

Feature	Why out	Deferred to
Deanonymisation of individuals	Permanent product and ethical boundary. The platform attributes infrastructure and produces confidence-scored investigative leads; it never asserts identity, and the UI must never imply it.	Never
Acting as primary MTA / inline blocking	Out-of-band only, mail flow never at risk. Inline blocking is conditional on the system first being proven and trusted in the live mail path.	Future phase
Full dynamic malware sandbox / detonation chamber	Integration hook only. Attachment static analysis covers the detection need.	Integration hook only
Offensive actions — takedown, hack-back, active probing	Passive enrichment only.	Never
Endpoint telemetry, network packet capture	Outside the email-forensics problem domain.	Out of product scope
Encrypted-body decryption without the institution's own keys	Not technically available without key custody.	Out of product scope
External anchoring of evidence roots to a third-party network	The internal hash-chained record with an exported integrity root achieves tamper-evidence at zero cost; an external service adds dependency and reset risk without adding capability.	Optional enhancement

6. Acceptance Criteria

M1 — Ingestion & Normalisation

- [] A single message file uploaded through the interface is parsed and appears in the queue with a verdict (derived — confirm with client)
- [] A bulk archive produces one queue entry per contained message (derived — confirm with client)
- [] Raw headers pasted without a body produce an analysis result covering every header-derived signal (derived — confirm with client)
- [] Messages are retrieved from the institution's mail platform without manual submission (derived — confirm with client)
- [] A hash of the raw message is recorded before any transformation, and recomputing it from the stored original reproduces the same value (derived — confirm with client)
- [] The stored original cannot be modified or deleted through the application (derived — confirm with client)
- [] Any byte range in the stored original can be addressed by header name or part index and offset (derived — confirm with client)
- [] A structurally malformed message completes analysis, is flagged as anomalous, and does not halt processing of others (derived — confirm with client)
- [] Two identical messages received separately resolve to a single queue entry (derived — confirm with client)
- [] A message submitted to the programmatic endpoint returns an analysis result (derived — confirm with client)

M2 — Detection Engine (NLP/ML)

- [] Every message receives a probability for each of the six defined classes (derived — confirm with client)
- [] A message containing urgency, authority pressure, secrecy or financial instruction has those cues listed individually (derived — confirm with client)
- [] A message matching a known payment-fraud pattern names that pattern in its output (derived — confirm with client)
- [] A message whose display name matches the protected list but whose sending domain is external and unaligned is identified as impersonation (derived — confirm with client)
- [] A sending domain within a defined edit distance of a protected domain, or using substituted characters, is flagged as a lookalike (derived — confirm with client)
- [] Hidden text, zero-width characters or invisible content are reported as concealment indicators (derived — confirm with client)
- [] A reply-formatted message with no matching prior thread history is flagged (derived — confirm with client)
- [] A body in a supported non-English language produces the same classification output as an English one (derived — confirm with client)
- [] Marking a verdict incorrect records the correction and places the item in the retraining queue (derived — confirm with client)

M3 — Header & Protocol Analysis

- [] The relay chain is parsed in correct chronological order with the earliest hop identified (derived — confirm with client)
- [] Given hops below the configured trust boundary, those hops are labelled unverified and the earliest reliable node is identified with stated reasoning (derived — confirm with client)
- [] Sender authentication is evaluated and alignment reported separately from pass/fail (derived — confirm with client)

- [] Every distinct combination of authentication result and alignment returns three statements: what it establishes, what it does not establish, and its effect on the investigation (derived — confirm with client)
- [] A message passing all authentication checks on a lookalike domain returns semantics text stating that authentication establishes control of the sending domain and not the identity of the sender (derived — confirm with client)
- [] Independently computed authentication results are compared against those present in the message, and disagreement is flagged (derived — confirm with client)
- [] A forwarded message with a valid forwarding chain is not penalised for authentication failures attributable to forwarding (derived — confirm with client)
- [] Mismatched return path, unrelated reply address, malformed identifier, or impossible inter-hop timing each produce a named anomaly (derived — confirm with client)
- [] The per-hop table displays hop number, timestamp, claimed host, actual address, reverse lookup, transport security, delay and trust status (derived — confirm with client)

M4 — Origin Traceability & Location

- [] All candidate originating addresses present in the message are extracted and listed (derived — confirm with client)
- [] One address is selected as earliest-reliable with written justification referencing the trust boundary (derived — confirm with client)
- [] The selected address resolves to country, region, city, coordinates and accuracy radius (derived — confirm with client)
- [] The selected address resolves to network operator, organisation and network range (derived — confirm with client)
- [] The infrastructure is classified into one of the defined types (derived — confirm with client)
- [] Every location output displays a confidence level and caveat, and both appear in the exported report (derived — confirm with client)
- [] The hop path renders on an interactive map with connecting lines (derived — confirm with client)
- [] Domain registration data returns registrar, creation date, age in days, nameservers and mail records where not redacted (derived — confirm with client)
- [] A domain under 30 days old, privacy-protected, or lacking mail records is flagged as high-risk (derived — confirm with client)
- [] A repeated lookup within the cache lifetime does not issue a new external request (derived — confirm with client)

M5 — Investigation & Correlation Graph

- [] Indicators of every defined type are extracted from each analysed message (derived — confirm with client)
- [] Messages sharing infrastructure and structural similarity above threshold are grouped under a single campaign identifier (derived — confirm with client)
- [] Every campaign view lists the shared indicators that justify the grouping; a campaign with no visible shared indicator is a defect (derived — confirm with client)
- [] Two messages with different wording, different domains and the same message skeleton are matched by structural fingerprint (derived — confirm with client)
- [] Shared network operator alone does not produce a strong campaign score, and the interface states that shared hosting is not shared actor (derived — confirm with client)
- [] Every indicator returns first-seen timestamp, sighting count, distinct case count and a familiarity band (derived — confirm with client)

- [] First-contact indicators are described as novelty and not as evidence of maliciousness in interface copy (derived — confirm with client)
- [] The first-contact signal is suppressed entirely until the history index holds the configured minimum volume (derived — confirm with client)
- [] Selecting any node in the correlation view displays its connected nodes (derived — confirm with client)
- [] Every campaign edge links through to the evidence justifying it (derived — confirm with client)
- [] Each message receives an origin-scenario classification with a confidence value (derived — confirm with client)
- [] The attribution output states infrastructure findings and confidence, and contains no assertion identifying a person (derived — confirm with client)
- [] Indicators export in the defined interchange formats and re-import without loss (derived — confirm with client)

M6 — Alerting, Dashboard & Reporting

- [] The queue supports filtering by score, verdict, date, sender and campaign, and sorting on each (derived — confirm with client)
- [] The detail view displays verdict and score, ranked contributions, authentication semantics, named conflicts, hop table, trace map, domain intelligence, URL and attachment panels, and linked cases (derived — confirm with client)
- [] A high-risk verdict raises an alert without requiring a user to open the message (derived — confirm with client)
- [] Alert destinations and thresholds are configurable and take effect without redeployment (derived — confirm with client)
- [] The executive dashboard displays volume trends, verdict distribution, most-targeted departments and campaign activity (derived — confirm with client)
- [] An exported report contains case identifier, evidence references, hashes, ingestion timestamp, header dump, findings, relay table, geolocation with caveats, domain intelligence, indicator list, attribution with confidence, examiner field, tool version, custody log and the integrity root (derived — confirm with client)
- [] An admissibility certificate template is generated alongside the report (derived — confirm with client)
- [] A case can be created, have messages attached, be assigned an owner, and move through each defined status (derived — confirm with client)
- [] Search returns matches across historical messages and cases by free text and by indicator value (derived — confirm with client)
- [] A message submitted through the end-user reporting path appears in the analyst queue (derived — confirm with client)

M7 — Evidence Integrity Layer

- [] A finding cannot be written without an evidence reference; the write is rejected by the storage layer, not by application code (derived — confirm with client)
- [] Every evidence reference resolves to a specific header or message part and byte range in the preserved original (derived — confirm with client)
- [] The application role can insert into the evidence record and cannot update or delete from it (derived — confirm with client)
- [] Altering any record row breaks the hash chain at that row and every row after it, and recomputation detects the break (derived — confirm with client)
- [] An integrity root is computed over records added since the previous root and is included in the exported report (derived — confirm with client)
- [] The verification tool runs with no access to the running system and reports pass or fail per item (derived — confirm with client)

- [] Given an exported report, altering one byte causes verification to fail and restoring it causes verification to pass (derived — confirm with client)
- [] Each of the five defined roles can perform exactly the actions assigned to it and no others (derived — confirm with client)
- [] Message content is masked by default, and revealing it writes an audit entry (derived — confirm with client)
- [] Retention periods are configurable per data class, and expired data is removed automatically with a record of the removal (derived — confirm with client)
- [] Data attached to a case under legal hold is not removed by retention expiry (derived — confirm with client)
- [] Stored evidence and logs remain within the required jurisdiction (derived — confirm with client)

M8 — Administration

- [] The trusted internal mail-server list is editable, and changes alter which hops the relay analysis treats as reliable (derived — confirm with client)
- [] The protected-individual and brand list is editable, and changes alter which messages are identified as impersonation (derived — confirm with client)
- [] Allow and block list entries accept an expiry and cease to apply after it (derived — confirm with client)
- [] Scoring weight ceilings and verdict thresholds are editable and take effect without redeployment (derived — confirm with client)
- [] The first-contact suppression floor is configurable (derived — confirm with client)
- [] The model registry displays version, training date, calibration date and measured performance, and a previous version can be restored (derived — confirm with client)

M9 — URL & Embedded Content Threat Engine

- [] URLs are extracted from plain-text and HTML bodies (derived — confirm with client)
- [] A QR code present in an inline image, an image attachment, or a page of a document attachment is decoded and its URL enters the same pipeline as body links (derived — confirm with client)
- [] A decoded QR URL is tagged with QR provenance, distinguishable from a body link (derived — confirm with client)
- [] A detected but undecodable QR code produces an explicit "present, undecodable" result rather than no result (derived — confirm with client)
- [] Decoding is attempted at all four rotations before failure is declared (derived — confirm with client)
- [] Links are expanded through their redirect chain and the final destination host reported (derived — confirm with client)
- [] A mismatch between anchor text and destination host is reported (derived — confirm with client)
- [] An attachment whose true type differs from its extension is flagged without the file being executed (derived — confirm with client)

M10 — Evidence Conflict Detector

- [] Each detected conflict is named and displays both sides of the contradicting evidence (derived — confirm with client)
- [] An authentication pass with a misaligned sender domain is reported as authenticated but misaligned (derived — confirm with client)
- [] An authentication pass alongside a high content-risk probability is reported as consistent with account compromise rather than spoofing (derived — confirm with client)
- [] An authentication failure with a valid forwarding chain and low content risk is reported as probable mailing-list traffic (derived — confirm with client)

- [] A QR-sourced destination host absent from every body link is reported as QR-versus-body divergence (derived — confirm with client)
- [] Conflicts detected are passed to scoring as an adjustment rather than as independent additive signals (derived — confirm with client)

M11 — Explainable Threat Scoring

- [] Listed signal contributions sum to the displayed total (derived — confirm with client)
- [] No single signal family can raise the score to the escalation threshold on its own (derived — confirm with client)
- [] Removing all first-contact signals from a message scored above threshold and rescored either leaves it above threshold or downgrades the verdict with the reason recorded (derived — confirm with client)
- [] Every score displays a confidence band rather than a point value alone (derived — confirm with client)
- [] Fixed disclaimer language appears with every score (derived — confirm with client)
- [] Each contribution links to the evidence reference it derives from (derived — confirm with client)
- [] A conflict adjustment applied to a score is displayed with its stated reasoning (derived — confirm with client)
- [] No verdict label expresses certainty; labels are Low, Elevated, High or Critical (derived — confirm with client)

M12 — ML Evaluation & Model Validation

- [] Evaluation reports precision, recall and F1 per class, not an aggregate figure alone (derived — confirm with client)
- [] The test-set size is displayed alongside the results (derived — confirm with client)
- [] A statement of what the corpus does not cover is displayed on the same screen as the results (derived — confirm with client)
- [] Evaluation runs without affecting live message processing (derived — confirm with client)
- [] Evaluation results are written to the model registry against the model version evaluated (derived — confirm with client)

7. Dependencies

External

- **Institutional mail platform** — the primary ingestion route. The build needs an account with API access granted; without it, messages can only be submitted manually.
- **QR decoding and document rasterisation libraries** — required for detecting codes in images and document attachments. Licence terms are unresolved and one candidate is copyleft in a way that matters if the prototype is distributed.
- **Public phishing corpora** — the sole training and evaluation source, since no institutional mail is available. Licence terms for training use and redistribution are unconfirmed, and no non-English corpus has been identified for the multilingual requirement.
- **Malicious-file reputation service** — hash and URL reputation lookups. The free tier permits roughly 5,760 lookups per day against a stated target of 10,000 messages per hour, so per-message live lookup is not possible. Severity is reduced because campaign correlation and first-contact baselining both operate on internally generated data and require no external lookups.
- **Domain registration lookup** — registrar, creation date, domain age and nameserver records. Registrant identity fields are commonly redacted, so domain age is the reliable signal.
- **Historical DNS resolution service** — prior resolution history for a sending domain. No provider with a suitable free tier has been identified.

- **Phishing URL feeds** — known-bad URL and host lists checked during analysis. One requires registration on terms not yet confirmed; one is open.
- **IP geolocation database** — held locally rather than queried per message. Licence terms permit this use but should be confirmed before distribution.
- **Manual threat-data import** — analyst-supplied indicator lists. The expected column schema is not yet defined.

Build sequence

- **The evidence record and access control come first.** Every module writes findings that must carry an evidence reference, and the reference cannot be retrofitted onto findings already written.
- **Ingestion (M1) precedes all analysis.** Nothing can be classified, traced or correlated before it can be received, hashed and made byte-addressable.
- **Administration (M8) precedes detection, header analysis and scoring.** The protected-individual list, the trusted-mail-server list and the weight configuration define what those modules compute against.
- **Header analysis (M3) precedes origin tracing (M4).** Origin selection consists entirely of choosing the earliest hop the trust boundary marks reliable.
- **Authentication semantics (M3) and the URL engine (M9) precede scoring (M11).** A scorer with two inputs demonstrates worse than no scorer.
- **Authentication semantics (M3) and detection (M2) precede conflict detection (M10).** Conflicts are comparisons between their outputs.
- **Conflict detection (M10) precedes final scoring (M11).** Contradictions adjust the score rather than adding to it.
- **The campaign graph (M5) precedes first-contact baselining (M5).** The baseline reads the same indicator index the graph builds.
- **Enrichment caching (M4) precedes threat correlation (M5).** Both draw on the same external quota, and an uncached pass exhausts it.
- **Every analysis module precedes report generation (M6).** The report renders the output of all of them.

8. Open Questions

1. What replaces the institution-donated training data? — blocks: classification accuracy, the reported evaluation figures, and any accuracy claim. Public corpora reintroduce era-and-encoding bias, and no non-English corpus has been identified for the multilingual requirement
2. What are the success metrics for this build? — blocks: measurable goals in section 2, and acceptance of every module. The system measures and discloses its own performance but commits to no target
3. Which QR decoding and rasterisation libraries, given the licence question? — blocks: QR detection, and any distribution or open-sourcing of the prototype
4. Are the public corpora licensed for training use and redistribution in a demonstration? — blocks: the evaluation run and any published artifact
5. Is an institutional mail platform account with API access provisioned? — blocks: the primary ingestion route
6. What is the minimum history volume before the first-contact signal is trusted rather than suppressed? — blocks: the suppression threshold. One thousand messages is proposed
7. Who authors the authentication semantics prose? — blocks: the semantics table. This is the most user-visible text in the product and must be technically exact; it needs one named owner
8. Does the conflict adjustment need its own calibration set, or is expert judgement on the weights acceptable for the prototype? — blocks: scoring conflict weights

9. What is the retention rule for the correlation graph and the indicator history index? — blocks: retention policy for those stores. Indicator history is most useful when kept longest and most sensitive when kept at all

Resolved since the previous revision:

- *Is full scope deliverable by this team?* — Closed by decision. The client has directed that the whole scope be built and that resourcing is not a constraint to plan against. All twelve modules remain in scope, and the build ordering in section 7 sequences work for demonstration readiness rather than triage. No sizing analysis informed this decision.
- *Is zero-cost tamper-evident anchoring viable?* — Yes. An internal append-only hash-chained record with a periodic integrity root exported alongside each report achieves tamper-evidence with no external service and no budget.
- *Does application-enforced integrity meet the evidentiary bar?* — Moot. The storage layer now enforces append-only writes and rejects any finding lacking an evidence reference.
- *Reduced:* the reputation-service quota question drops from high to medium severity, since campaign correlation and first-contact baselining require no external lookups.

9. Assumptions

- A mail platform account with API access is available for development and demonstration — inferred; the platform was confirmed, the test account was not
- Public phishing corpora are legally usable for training and redistribution in a demonstration context — inferred, and raised as an unresolved licence question
- Free-tier quotas for the chosen threat feeds remain available and unchanged through the build — inferred; severity reduced, since correlation and baselining need no feed calls
- Geolocation data and other open-source components remain free under terms compatible with this use — inferred
- QR decoding and document rasterisation libraries can be bundled under their licences — inferred; one candidate is copyleft in a way that matters on distribution
- Graph traversal by recursive query performs adequately at demonstration scale — inferred; named as the safe default for a prototype
- The demonstration dataset is prepared and cached in advance, and the history index is seeded before any demonstration; nothing on the demonstration path depends on an external service responding
- Team size is six — from the source document; scope has since roughly tripled against that figure

Source Notes

- Success Metrics undefined in `mvp-scope.md` — affects §2 Goals, which carries a warning line instead of measurable targets
- Client name taken as "Smart India Hackathon" per consultant confirmation during DISCOVERY; the source document names the organisation as AICTE — Cyber Security Cell — affects header
- Product, vendor and component names present in `mvp-scope.md` and `arch.md` were replaced with capability language per the skill's naming constraint — affects §5, §4, §6 and §7. Standards and protocol terms were retained as domain terms
- Regenerated 2026-08-31 from a rebuilt `mvp-scope.md` after the previous `mvp-scope.md` and `prd.md` were deleted. The rebuild sources `discovery.md` and `Architecture Update v2`, which added eight features and four modules to the previous eight-module scope — affects every section
- The storage decision changed from a document store to a relational store during this revision, because the evidence design requires storage-enforced append-only writes and constraint-enforced evidence references — affects §6 M7 criteria and §7 build sequence